Cheatsheet AZ-305 — 01 · Identity: Microsoft Entra ID licensing and governance

1. Licensing: what each tier unlocks

Feature	Free	P1	P2	Governance (add-on)
Users, groups, basic SSO, Entra Connect	✓	✓	✓	✓
Smart Lockout (brute force / password spray)	✓	✓	✓	✓
SSPR (password change)	✓	✓	✓	✓
Security Defaults (global MFA, legacy auth blocked, all-or-nothing)	✓	—	—	—
SSPR with **writeback** to AD DS	✗	✓	✓	✓
Conditional Access (conditions you define yourself)	✗	✓	✓	✓
Dynamic groups, hybrid join, on-prem Password Protection	✗	✓	✓	✓
Identity Protection (user risk / sign-in risk, risk-based CA)	✗	✗	✓	✓
PIM (eligible roles, JIT, approval, auditing)	✗	✗	✓	✓
Access Reviews (groups, apps, roles, guests)	✗	✗	✓	✓ (extended)
Entitlement Management (access packages)	✗	✗	✗	✓
Lifecycle Workflows (onboarding / offboarding)	✗	✗	✗	✓

Rule: "risk-based" → P2 · "just-in-time / eligible" → P2 · "access package" → Governance · "automatic onboarding" → Governance · "Free edition / minimize licensing" → look for something included by default (Smart Lockout, Security Defaults).

2. Identity Protection vs Identity Governance

	Identity Protection	Identity Governance
Question	Is this identity at risk right now?	Should this access exist?
Nature	Detection (ML) + response via CA	Lifecycle and recertification
Signals	user risk (leaked credentials), sign-in risk (impossible travel, anonymous IP/malware)	membership, roles, packages, joiners and leavers
Typical action	require MFA, block, force reset	activate temporarily, revoke, expire, deprovision
Frequency	continuous, every sign-in	periodic / on demand
License	P2	P2 (basic) / Governance (full)

3. The four pieces of Governance

Piece	What it does	Verb in the wording	Exam details
PIM	JIT activation of roles (Entra ID, Azure RBAC, groups)	"temporary", "just-in-time", "eligible", "no standing access", "justification"	Includes **alerts** (roles outside PIM, too many admins), **audit history** of activations and **access reviews of roles**. Recommended with MFA + approval
Access Reviews	Periodic recertification; whoever does not confirm loses access	"review periodically", "self-attestation", "remove if no response", "guests"	Reviewers: self, manager, designated. Configurable recurrence. Action on no response: remove
Entitlement Management	Access packages (groups + apps + sites) with request, approval and **expiration**	"access package", "request access", "partner / external collaboration", "expire"	Catalogs, policies per audience (internal / external), connected organizations
Lifecycle Workflows	Automates joiner / mover / leaver	"onboarding", "offboarding", "when a user leaves"	Triggers based on HR attributes (hire / leave date)

Access Reviews is part of Governance and embedded in PIM (roles) and Entitlement (packages). If the options only offer PIM for "review administrative roles + alerts + history" → PIM. If they offer Access Reviews for "groups / guests" → Access Reviews.

4. Conditional Access: anatomy of a policy

Block	What it contains	Examples
Assignments / Conditions	who, which app, from where, which device, which risk	users who manage production, app "Microsoft Azure Management", location, platform, sign-in risk
Grant	what is required to **grant** access	Require MFA · Require compliant device · Require hybrid joined device · Require approved app (AND / OR)
Session	what happens **after** granting	Sign-in frequency (e.g. 14 days) · Persistent browser session · App enforced restrictions

- "Require MFA / compliant / hybrid joined" → **Grant**.
- "Reduce MFA frequency following best practices" → **Sign-in frequency (Session)**, not the legacy "Remember MFA".
- "Register MFA methods" → **Authentication methods policy**, not CA.
- **Security Defaults** and custom CA are **mutually exclusive**.

5. Hybrid identity

	PHS	PTA	ADFS
Where the password is validated	Cloud (synced hash)	On-prem (agents)	On-prem (federation)
Survives on-prem network outage	**Yes**	No	No
Requirement "password hashes only on-prem"	✗	✓	✓
Enables Identity Protection leaked credentials	✓	Only if PHS as well	No
Recommendation	PHS (+ Seamless SSO). PTA with PHS as backup		

- **Entra Connect Health** → alerts on synchronization failures.
- **"License agreement failed"** when assigning a license → missing **Usage Location** (not synced from AD DS).
- **Custom domain:** must be public and verifiable with **TXT**; .local never works.
- **Non-routable UPN suffixes** → add a public UPN suffix before syncing.
- **Entra Domain Services** → LDAP / Kerberos / NTLM **inside Azure** without VPN to on-prem, fed from Entra ID.
- **Application Proxy + KCD** → publish an on-prem app with IWA/Kerberos, SSO, no VPN.
- **Lighthouse** → manage resources in **other tenants** without guest accounts. **B2B** → invite **users** as guests.
- **Workday provisioning:** 1 app can cover employees and contractors with conditional mapping (IIF); 1 provisioning agent per target domain (minimum).

6. Decision tree

```
What does the wording ask for?
├─ Detect risk / leaked credentials / impossible travel ..... Identity Protection (P2)
├─ Require MFA or device at sign-in ........................... Conditional Access · Grant (P1)
├─ How often to repeat MFA .................................... CA · Session · Sign-in frequency
├─ Which MFA methods can be registered ........................ Authentication methods policy
├─ Temporary role with justification / approval ................ PIM (P2)
├─ Periodically review groups / guests / apps .................. Access Reviews (P2)
├─ Review administrative roles + alerts + history .............. PIM (P2)
├─ Package of resources that is requested and expires ..... Entitlement Management (Governance)
├─ Automatic joiners and leavers ............................... Lifecycle Workflows (Governance)
├─ Brute force without a license ............................... Smart Lockout (Free)
└─ MFA for everyone without granularity and without a license ..... Security Defaults (Free)
```

7. Signals → answer

Wording	Answer
"risk-based", "leaked credentials", "atypical travel"	Identity Protection
"Just-In-Time", "eligible", "standing permissions"	PIM
"every three months", "self-attest", "removed if no response"	Access Reviews
"inactive admins list" (listing only)	Sign-in logs / Entra Workbooks
"access package", "request access", "expire after"	Entitlement Management
"hybrid joined device AND MFA"	Grant control in the existing policy
"reduce MFA prompts, 14 days, best practice"	Sign-in frequency
"Free tenant", "minimize licensing", "password spray"	Smart Lockout
"custom domain", ".local"	Public domain with TXT; .local is a distractor
"LDAP", "no VPN allowed"	Entra Domain Services
"MSP manages multiple tenants"	Lighthouse

8. Mistakes to avoid

1. Confusing P1 with P2: PIM, Identity Protection and Access Reviews are **P2**.
2. Choosing Identity Protection for "require MFA for everyone always" → that is CA Grant.
3. Choosing PIM for "periodic review of a group" when Access Reviews is among the options.
4. Choosing Session control to require MFA → Session governs after access is granted.
5. Choosing .local as a custom domain.
6. Choosing B2B when the wording forbids guest accounts.